Forenzički detektor potpisa fajlova

Milos Marinkovic

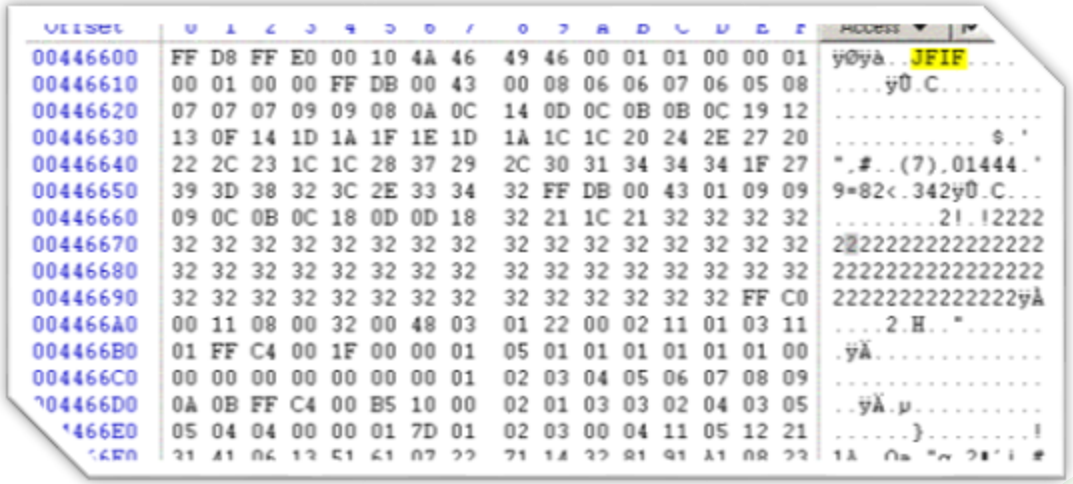
Lažne ekstenzije u digitalnoj forenzici

- Napadači rutinski menjaju ekstenzije fajlova da bi sakrili štetne programe. U forenzičkoj praksi ovo predstavlja ozbiljan izazov:
- Malware kao dokument: trojan.exe → ugovor.pdf
- Eksploiti kao slike: exploit.dll → slika.jpg
- Skriptovi kao tekst: virus.js → readme.txt
- Forenzičar bez odgovarajućih alata mora ručno proveravati svaki fajl, što je sporo i podložno greškama.



ANALIZA DIGITALNIH POTPISA

- Svaki fajl ima jedinstveni "digitalni potpis" u svojim prvim bajtovima. Ovi "magic brojevi" ne mogu da se lažiraju:
- **JPEG** slika uvek počinje sa: `FF D8 FF`
- **Windows EXE** uvek počinje sa: `4D 5A`
- **PDF** dokument uvek počinje sa: `25 50 44 46`
- `Program` **nezavisno od ekstenzije određuje stvarni tip fajla.** To je kao DNK test za digitalne dokaze.



FUNKCIONALNOSTI

1. ANALIZA POJEDINAČNIH FAJLOVA

Detekcija stvarnog tipa fajla

Prikaz heksadecimalnog potpisa

Upoređivanje ekstenzije i stvarnog sadržaja

Brza verifikacija autentičnosti

2. SKENIRANJE CELIH FOLDERA

Automatska analiza svih fajlova u direktorijumu

Obeležavanje sumnjivih fajlova (crveno/zeleno)

Generisanje statistike (koliko % je sumnjivo)

Izveštaj po kategorijama

3. DEMO MOD ZA TESTIRANJE

Automatsko kreiranje test fajlova

Bez potrebe za spoljnim podacima

Idealno za edukaciju i demonstracije

Kada i gde se alat koristi?

SCENARIJI UPOTREBE:

ANALIZA KONFISKOVANIH UREĐAJA

- Brza triaža USB diskova i hard diskova
- Identifikacija potencijalnog malware-a
- Kategorizacija dokaza po tipovima

INCIDENT RESPONSE

- Provera sumnjivih fajlova na kompromitovanim sistemima
- Detekcija sakrivenih backdoor-a
- Alat nalazi fajlove koje su napadači preimenovali da sakriju svoje zlonamerne programe.
- Analiza download foldera

EDUKACIJA I OBUKA

- Demonstracija tehnika sakrivanja malware-a
- Praktični primeri forenzičke analize
- Testiranje bez rizika od infekcije
- **FAZE ISTRAGE:** Početna analiza → Detaljna istraga → Dokumentovanje

TEST SLUČAJEVI

TEST FAJLOVI KOJE PROGRAM SAM KREIRA:

- cisti_kod.txt → **OTKRIVENO: EXE fajl** ⚠️
- slika_priroda.jpg → **OTKRIVENO: PDF dokument** ⚠️
- izvestaj.doc → **OTKRIVENO: ZIP arhiva** ⚠️
- normalna_slika.jpg → **JPEG slika** ✅
- beleške.txt → **Tekstualni fajl** ✅

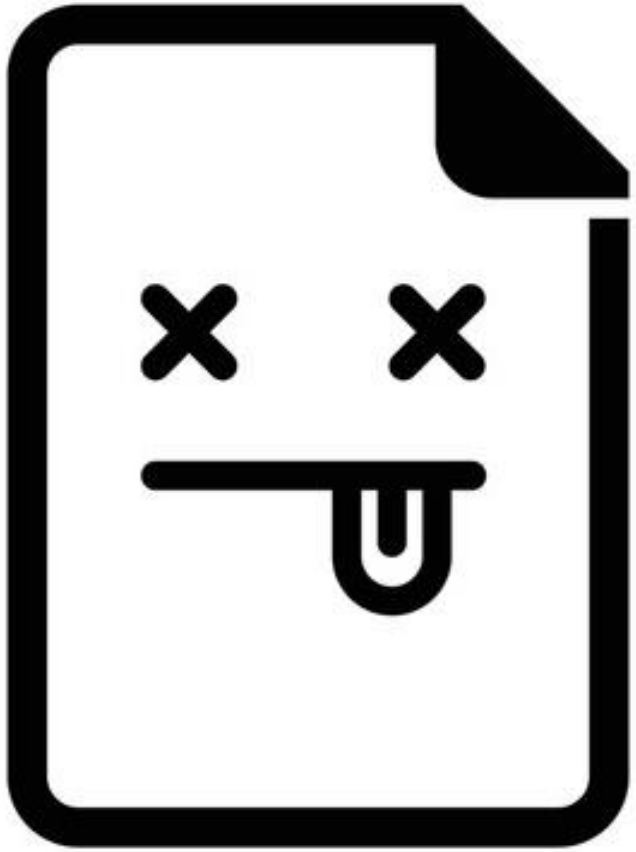
REZULTAT SKENIRANJA:

- Ekstenzije se ne poklapaju sa stvarnim sadržajem
- Moguć sakriven malware ili nelegalni sadržaj

Trenutna ograničenja

- **Ne analizira sadržaj** fajlova (samo headere)
- **Ne detektuje** napredne tehnike sakrivanja
- **Nema deep scan** za arhivirane fajlove

?ŠTA SU DVOSTRUKE EKSTENZIJE?



CORRUPTED FILE

- **Tehnika manipulacije** koju napadači koriste da prevare korisnike:
  - Fajl se zove: ugovor.pdf.exe
  - Windows prikazuje: ugovor.pdf 📄
  - Sistem izvršava: .exe ⚠️
  - **Korisnik vidi poznati tip fajla, ali pokreće program!**

ZAŠTO LJUDI PADAJU NA OVO?

Psihologija u akciji:

- 📄 **.pdf** = "samo dokument"
- 📸 **.jpg** = "samo slika"
- 💌 **"Od banke/šefa"** = moram da otvorim!
- **U 67% phishing napada se koristi ovaj trik!**

Potencijalna unapređenja

Baza potpisa: Dodavanje mnogo više magic brojeva za prepoznavanje gotovo svih vrsta fajlova koje možete sresti.

Antivirus integracija: Automatska provera fajlova preko antivirus servisa da se odmah vidi da li su zaraženi.

Automatski izveštaji: Kreiranje gotovih izveštaja u PDF-u ili na veb stranici sa svim rezultatima skeniranja.

GUI interfejs: Grafičko okruženje sa dugmadima i prozorima koje olakšava korišćenje bez komandne linije.

Mrežno skeniranje: Mogućnost da se skeniraju fajlovi sa drugih računara u mreži ili sa servera.

Hashing podrška: Računanje jedinstvenih digitalnih otisaka fajlova da bi se znalo da li su se fajlovi promenili.

Kako veštačka inteligencija menja forenziku?

AI u analizi fajlova:

- **Pattern recognition** - uči iz prethodnih napada
- **Anomaly detection** - nalazi neobične kombinacije
- **Predictive analysis** - predviđa buduće metode

Primeri iz prakse:

- **Google's Chronicle** - ML za detekciju nepoznatih potpisa
- **Microsoft Defender** - AI za zero-day detekciju
- **CrowdStrike** - Behavioral analysis